

用户设置指南-for-operator

用户设置指南

new-api 菲律宾/新加坡双站 · 阿里云国际站 RAM 访问控制

账号 5108890064395960 · 主 region ap-southeast-6 (马尼拉) · 备 region ap-southeast-1 (新加坡)

控制台入口: <https://ram.console.aliyun.com/users>

文档日期: 2026-09-26

0. 速查

0.1 七类角色 → 用户组 → 权限策略 (开发 = 双身份, 占 2 个组)

七类角色 → 用户组 → 权限策略 映射

每组左列是角色、中列是用户组、右列是挂在该组上的策略。人是控制台身份，程序是 AK 身份，两者分开。

管理人员 admin 管账号：建用户/发 AK/绑策略；业务资源只能	用户组 admin_group	权限策略 newapi-admin-identity newapi-enforce-mfa newapi-audit-protect
财务 finance 只看账单与费用，不能改任何东西；无 AK	用户组 fin_group	权限策略 AliyunBSSReadOnlyAccess newapi-audit-protect
开发 dev (人·控制台) 非生产读写；生产只读；须绑 MFA；不发 AK	用户组 dev_group	权限策略 newapi-ops-operator newapi-enforce-mfa newapi-audit-protect newapi-prod-boundary newapi-prod-oss-guard
开发程序 dev-program (纯 AK) 非生产 OSS 写 + 镜像推拉 + 全账号只读；无 MFA	用户组 dev-program_group	权限策略 newapi-dev-program newapi-prod-boundary newapi-prod-oss-guard
开发 Leader 人 + 程序双身份：改非生产、持有 AK	用户组 dev_group + dev-program_group	权限策略 newapi-ops-operator newapi-enforce-mfa newapi-audit-protect newapi-prod-boundary newapi-prod-oss-guard newapi-dev-program
初级运维 ops 非生产运维；生产只读；不可销毁；须绑 MFA	用户组 ops_group	权限策略 newapi-ops-operator newapi-enforce-mfa newapi-audit-protect newapi-prod-boundary newapi-prod-oss-guard
运维 Leader 生产可写不可销毁；应急通道；优先走 IaC	用户组 ops-prod_group + ops_group	权限策略 newapi-ops-operator newapi-enforce-mfa newapi-audit-protect

角色	用户组	权限策略	一句话职责
管理人员 admin	admin_group	newapi-admin-identity + newapi-enforce-mfa + newapi-audit-protect	管账号：建用户、发AK、绑策略；对业务资源只能看
财务 finance	fin_group	AliyunBSSReadOnlyAccess + newapi-audit-protect	只看账单与费用，不能改任何东西；无AK，纯控制台
开发 dev (人·控制台)	dev_group	newapi-ops-operator + newapi-enforce-mfa + newapi-audit-protect + newapi-prod-boundary + newapi-prod-oss-guard	非生产读写、生产只读；人用控制台 + MFA，不发AK
开发程序 dev-program (纯AK)	dev-program_group	newapi-dev-program + newapi-prod-boundary + newapi-prod-oss-guard	非生产OSS写 + 镜像推拉 + 全账号只读；无控制台
开发 Leader	dev_group + dev-program_group	两组策略并集（6条）	双身份：人身份改非生产；程序身份持AK
初级运维 ops	ops_group	newapi-ops-operator + newapi-enforce-mfa + newapi-audit-protect + newapi-prod-boundary + newapi-prod-oss-guard	非生产运维读写；生产只读；不可销毁
运维 Leader	ops-prod_group (+ ops_group 保留非生产写)	newapi-ops-operator + newapi-enforce-mfa + newapi-audit-protect	生产读写（不可销毁）；应急通道

七类角色只对应6个用户组：开发是**双身份**（人账号进 dev_group、AK 账号进 dev-program_group），开发 Leader 同时持这两个身份；运维 Leader 在 ops_group 之外再叠加 ops-prod_group。身份各自独立，权限不叠加到同一个账号上。

0.2 七条不能破的规矩

- 1. **策略只挂用户组，不挂用户**。禁止 `AttachPolicyToUser` —— 会退回「两层漂移」：改了组没改用户级 → 改了不生效、删了不收敛。
- 2. **Deny 恒胜 Allow**。要给某人生产写权限，必须让他**不在**挂了 `newapi-prod-boundary` 的组里，加 Allow 策略救不回来。
- 3. **人 / 程序身份分开**。人用控制台 + MFA；程序用 AK。绝不把「带生产权限的长期 AK」发给个人电脑。
- 4. **纯程序身份不建控制台登录**。`dev-*` / `cicd-*` / `iac-*` 只勾「OpenAPI 调用访问」。
- 5. **加入 `admin_group` / `ops-prod_group` 前必须先绑 MFA**，否则 `newapi-enforce-mfa` 会 Deny 除 MFA 自助动作外的一切。
- 6. **用户组备注只写「用途 / 策略 / 边界」** —— 上限 128 字符，不写 AK/密码/内网 IP。备注**不等于权限**，改备注不会改权限。
- 7. **组备注命名约定：人身份组带（人）后缀**（`管理人员组(人)`、`非生产运维组(人)`、`生产运维组(人)`、`财务组(人)`、`开发组(人)`、`所有资源组(人)`、`主账号身份组(人)`）；**程序身份组不带**（`开发程序身份组(纯AK,无控制台)`、`Terraform IaC组`、`CI/CD镜像推送组`）。看一眼后缀就知道这组是给人用的还是给 AK 用的。

1. 先读懂模型：三分钟建立正确心智

1.1 权限怎么算出来的

用户（RAM User）

- └ 属于 0..N 个用户组（User Group）
 - └ 每个组挂 0..N 条权限策略（Policy）
 - └ 策略 = 一组 Statement，每条 Effect 是 Allow 或 Deny

最终权限 = 所有来源的并集，但 Deny 优先

阿里云 RAM 是**默认拒绝**模型：**没有显式 Allow = 拒绝**。
所以「只读」有两种写法：① 显式 Allow 只读动作；② 什么都不 Allow（靠默认拒绝）。

1.2 三种边界，管三件不同的事

边界手段	管什么	本项目用法
策略里的 <code>Action</code>	能调哪些 API	<code>newapi-ops-operator</code> 的 Allow/Deny 列表
策略里的 <code>Resource</code> / <code>Condition</code>	能操作哪些资源	<code>newapi-prod-boundary</code> 用 <code>acs:ResourceGroupId</code> 锁生产资源组
用户组	谁能拿到这些权限	六个组 = 六种职责

1.3 关键概念： `acs:ResourceGroupId` 是唯一可靠的「生产隔离」抓手

`newapi-prod-boundary` 靠它把生产资源（`rg-ph-mn1` / `rg-sg`）之外的写动作全部拒绝：

```
{
  "Effect": "Deny",
  "NotAction": [ "*:Describe*", "*:List*", "*:Get*", "*:Query*" ],
  "Resource": [ "*" ],
  "Condition": { "StringEquals": {
    "acs:ResourceGroupId": [ "rg-aek4nyivmmsb6iy", "rg-aek4zvb3ldoiyua" ]
  }}
}
```

读法：在 `rg-ph-mn1` 或 `rg-sg` 里的资源上，只要动作不是 `Describe/List/Get/Query`，一律拒绝。

⇒ 生产只读，写全挡。

3. 用户组逐条详解（10 个）

Alibaba Cloud

工作台

搜索

费用 备案 企业 支持 工单

yanxuewei

概览

设置

身份管理

用户

用户组

角色

权限管理

权限策略

授权

集成管理

SSO 管理

OAuth 应用（公测）

多账号身份权限

访问分析

分析器

分析结果

AI 治理中心

RAM 访问控制 / 用户组

用户组

创建用户组

1 筛选用户组名称、显示名称、备注

用户组名称 / 显示名称	备注	创建时间	操作
☐ dev_group	开发组(人) 策略:newapi-ops-...	2026年9月26日 12:15:41	添加用户 新增授权：
☐ fin_group	财务组(人) 策略:AliyunBSSRe...	2026年9月26日 11:53:08	添加用户 新增授权：
☐ ops-prod_group	生产运维组(人) 策略:newapi-op	2026年9月25日 22:58:23	添加用户 新增授权：
☐ dev-program_group	开发程序身份组(纯AK,无控制台)	2026年9月25日 22:29:58	添加用户 新增授权：
☐ admin_group	管理人员组(人) 策略:newapi-ad	2026年9月25日 21:03:27	添加用户 新增授权：
☐ iac-terraform_group	Terraform IaC组 策略:new...	2026年9月25日 11:18:37	添加用户 新增授权：
☐ cicd-push_group	CI/CD镜像推送组 策略:newapi-	2026年9月25日 11:17:59	添加用户 新增授权：
☐ ops_group	非生产运维组(人) 策略:newapi-q	2026年9月25日 11:17:35	添加用户 新增授权：
☐ power_user_group	所有资源组(人) 策略:PowerUser	2026年9月25日 11:17:12	添加用户 新增授权：
☐ super_group	主账号身份组(人) 策略:Administ	2026年9月24日 22:36:07	添加用户 新增授权：

3.0 各组「备注」一览（已写入云端，可直接复制）

每个用户组的 备注（Comments） 字段已统一改为中文，格式固定为三段：

<角色/用途> | 策略:<挂了哪些策略> | 注意:<边界与坑>

目的：在控制台「用户组」列表页一眼看清**这个组能干什么、绝对不能干什么**，不用点进去逐个查策略。

RAM 备注 **上限 128 字符**（中文按 1 字符计），`ops_group` 已用到 **127 字符**，几乎顶到上限——再加内容要先删旧内容。

组名	字符数	状态
<code>admin_group</code>	103	✓
<code>cicd-push_group</code>	91	✓
<code>dev_group</code>	122	✓
<code>dev-program_group</code>	119	✓
<code>fin_group</code>	104	✓
<code>iac-terraform_group</code>	105	✓
<code>ops-prod_group</code>	106	✓
<code>ops_group</code>	127	✓
<code>power_user_group</code>	97	✓
<code>super_group</code>	49	✓

实际文本（与云端逐字一致）：

`admin_group`

管理人员组(人)|策略:`newapi-admin-identity+audit-protect+enforce-mfa`|注意:非生产全量管理,生产仅只读;登录控制台须绑MFA;策略仅组级承载,禁止用户级绑定

`fin_group`

财务组(人)|策略:`AliyunBSSReadOnlyAccess+newapi-audit-protect`|注意:仅查账单与费用,无资源写权限;纯控制台无AK;要看资源清单可另加`ReadOnlyAccess`

`ops_group`

非生产运维组(人)|策略:`newapi-ops-operator+enforce-mfa+audit-protect+newapi-prod-boundary+newapi-prod-oss-guard`|注意:生产只读,写全挡;须绑MFA;策略仅组级承载

`ops-prod_group`

生产运维组(人)|策略:`newapi-ops-operator+enforce-mfa+audit-protect`|注意:生产可写不可销毁,可删生产桶对象;优先走IaC,手工变更须补回Terraform;成员暂空

`dev_group`

开发组(人)|策略:`newapi-ops-operator+enforce-mfa+audit-protect+newapi-prod-`

boundary+newapi-prod-oss-guard|注意:非生产读写,生产只读;AK走dev程序组

dev-program_group

开发程序身份组(纯AK,无控制台)|策略:newapi-dev-program+newapi-prod-boundary+newapi-prod-oss-guard|注意:生产只读,写全挡;禁开LoginProfile;AK严禁提交git

iac-terraform_group

Terraform IaC组|策略:newapi-iac-terraform+newapi-audit-protect|注意:唯一能改生产OSS桶配置的自动化身份,故意不挂prod边界;变更须走流水线,勿手工跑

cicd-push_group

CI/CD镜像推送组|策略:newapi-cicd-acr-push+newapi-audit-protect|注意:仅ACR镜像推拉权限;只发AK给流水线,不开控制台;勿并入其它组

power_user_group

所有资源组(人)|策略:PowerUserAccess+newapi-enforce-mfa+newapi-audit-protect|注意:权限近账号级,须绑MFA;仅临时查问题用,勿长期加人

super_group

主账号身份组(人)|策略:AdministratorAccess等20条|注意:是第二个主账号,不要轻易加人

维护方式: 不要手工在控制台一个个改(易漏、易写错)。用配套脚本,备注定义在脚本的 comments_for() 函数里(唯一真源):

```
export ALIYUN_BIN="$HOME/.workbuddy/binaries/aliyun-cli/aliyun"
bash ram_group_annotate.sh check      # 只读: 对比当前 vs 目标
bash ram_group_annotate.sh apply      # 备份 + 写入(幂等, 已一致则 SKIP)
bash ram_group_annotate.sh verify     # 校验 10/10 一致 + 长度合规
bash ram_group_annotate.sh rollback   # 从最近备份恢复
```

3.1 admin_group — 账号管理

项	内容
控制台备注	管理人员组(人)·非生产全量管理、生产只读、须绑 MFA (全文见 §3.0)
创建	2026-09-25 21:03
策略	newapi-admin-identity + newapi-enforce-mfa + newapi-audit-protect
成员	admin
能做什么	建/删/改用户与用户组、建/删/改权限策略、绑定解绑策略、签发/禁用/删除 AK、管 MFA、管 ActionTrail; 查看全部业务资源

项	内容
不能做什么	改业务资源（VPC/ECS/RDS/OSS 配置一律写不了）、查账单明细（只有 <code>bss:Describe* / Query*</code> ）
谁该进	账号管理人员，1~2 人。必须已绑 MFA

3.2 ops_group — 非生产运维

项	内容
控制台备注	非生产运维组 · 生产只读、写全挡、须绑 MFA、策略仅组级承载（全文见 §3.0）
创建	2026-09-25 11:17
策略	<code>newapi-ops-operator</code> + <code>newapi-enforce-mfa</code> + <code>newapi-audit-protect</code> + <code>newapi-prod-boundary</code> + <code>newapi-prod-oss-guard</code>
成员	ops（ <code>zhangzijun</code> / <code>xiangdong</code> 已于 2026-09-26 迁到 <code>dev_group</code> ）
能做什么	非生产资源（ <code>rg-nonprod</code> ）全读写；生产资源只读（VPC/VPC 路由/安全组/桶内容都能看）
不能做什么	改任何生产资源；删实例/库/集群/桶（ <code>ops-operator</code> 的 Deny）
谁该进	初级运维（日常运维同学）、需要看生产的开发同学
注意	组语义 = 非生产运维，开发同学请进 <code>dev_group</code> （权限完全相同，只是语义分开）。若有人要求「临时改生产」，不要解绑 <code>boundary</code> —— 那会让全组一起失去保护，正解是把他加到 <code>ops-prod_group</code>

3.3 ops-prod_group — 生产运维（人类）

项	内容
控制台备注	生产运维组(人) · 生产可写不可销毁、可删生产桶对象、优先走 IaC（全文见 §3.0）
创建	2026-09-25 22:58
策略	<code>newapi-ops-operator</code> + <code>newapi-enforce-mfa</code> + <code>newapi-audit-protect</code> （刻意不挂两条生产边界）
成员	空（留备）
能做什么	生产资源可读写：改安全组、调路由、重启实例、改桶配置、改 RDS 参数
不能做什么	删实例/删 VPC/删 vSwitch/删库/删集群/删负载均衡/删桶（ <code>ops-operator</code> 的 Deny）

项	内容
	⚠️ 可以删生产桶对象 (<code>oss:DeleteObject</code> 不在 Deny 列表, 也没有 <code>oss-guard</code> 兜底)
谁该进	运维 Leader (专职生产运维的负责人)。加入前必须绑 MFA
注意	① 这是「应急手工通道」, 日常生产变更优先走 <code>iac-terraform</code> (IaC), 手工改完要补回 Terraform; ② 一旦加入, 他就同时具备「非生产写 + 生产写」= 全量运维, 因为 <code>ops-operator</code> 本身没有资源组限制

3.4 `dev-program_group` — 开发程序身份

项	内容
控制台备注	开发程序身份组(纯AK,无控制台) · 生产只读写全挡、禁开 LoginProfile (全文见 §3.0)
创建	2026-09-25 22:29
策略	<code>newapi-dev-program</code> + <code>newapi-prod-boundary</code> + <code>newapi-prod-oss-guard</code>
成员	<code>dev-zhangzijun</code> 、 <code>dev-xiangdong</code>
能做什么	用 AK 调云 API: 查所有资源、往非生产桶读写、推拉 <code>newapi</code> 命名空间镜像
不能做什么	生产资源任何写操作; RAM 相关一切; 账单写操作
谁该进	只有程序身份 (<code>dev-*</code>)。人类账号不要进这个组 —— 这里的身份没有控制台登录
注意	这三个成员必须 没有 LoginProfile。用脚本创建时会校验

3.5 `iac-terraform_group` — IaC 程序身份

项	内容
控制台备注	Terraform IaC组 · 唯一能改生产 OSS 桶配置的自动化身份、故意不挂生产边界 (全文见 §3.0)
创建	2026-09-25 11:18
策略	<code>newapi-iac-terraform</code> + <code>newapi-audit-protect</code>
成员	<code>iac-terraform</code>
能做什么	Terraform 管所有业务资源 (含生产桶配置、生命周期、复制规则、资源组归属)
不能做什么	RAM 身份相关一切 (41 项显式 Deny); 改不了 ActionTrail 审计对象
谁该进	CI/CD 里的 Terraform 运行器。AK 只放 CI secret, 不发到人

3.6 cicd-push_group — CI 镜像推送

项	内容
控制台备注	CI/CD镜像推送组 · 仅 ACR 镜像推拉、只发 AK 给流水线、勿并入其它组（全文见 §3.0）
创建	2026-09-25 11:17
策略	newapi-cicd-acr-push + newapi-audit-protect
成员	cicd-push
能做什么	推/拉 newapi 命名空间的镜像，取仓库临时口令
不能做什么	其他命名空间、删仓库、任何其他服务
谁该进	CI 流水线。AK 只放 CI secret

3.7 power_user_group — 应急临时全权组（已补两条护栏）

项	内容
控制台备注	所有资源组(人) · 权限近账号级、须绑 MFA、仅临时查问题用（全文见 §3.0）
策略	PowerUserAccess （系统策略：除 RAM 身份管理外全权，含所有资源组的生产写） + newapi-enforce-mfa + newapi-audit-protect （2026-09-26 补）
成员	0 人
定位	应急通道 —— 临时把某人加进来查跨资源组的问题，用完立刻移出
能做什么	几乎一切业务资源写操作（含生产）；照样管不了 RAM 身份
不能做什么	RAM 用户/组/策略相关（PowerUserAccess 排除 RAM 管理，因此不能自建 AK、不能改自己的组策略、不能 detach 策略）
已补护栏	① newapi-enforce-mfa → 未完成 MFA 的控制台会话里，除 11 个 MFA/登录类白名单动作外全部 Deny（Deny 恒胜 PowerUserAccess 的 Allow）；② newapi-audit-protect → 两个审计桶的 actiontrail/ 前缀对象不可写/不可删（10 个动作）
残留风险	① acs:MFAPresent 对 AK 调用不判定 → 拿到 AK 就绕过 MFA 强制（但本组不能自建 AK，只要别发 AK 给人就没事）；② PowerUserAccess 不受资源组边界约束，过 MFA 后能写生产；③ newapi-audit-protect 只保护 OSS 对象，不挡 actiontrail:DeleteTrail / StopLogging 这类 API；④ 本组没挂 newapi-prod-oss-guard → 过 MFA 后可删生产桶对象

项	内容
规矩	禁止长期驻留 ：加入 → 用完 → 移出，三步必须闭环。要长期生产权限走 ops-prod_group

3.8 super_group — 主账号身份（历史遗留）

项	内容
控制台备注	主账号身份组(人) · 管理人员权限（全文见 §3.0）
创建	2026-09-24 22:36
策略	20 条托管策略 ：AdministratorAccess、AliyunRAMFullAccess、AliyunECSFullAccess、AliyunVPCFullAccess、AliyunOSSFullAccess、AliyunRDSFullAccess、AliyunSLBFullAccess、AliyunEMRFullAccess、AliyunEIPFullAccess、AliyunBatchComputeFullAccess、AliyunSupportFullAccess、AliyunSTSAssumeRoleAccess + 7 条只读
成员	yanxuewei
能做什么	一切，等同主账号
注意	⚠ 权限等同主账号，能改账号级配置与 RAM 策略本身。 日常操作请走 admin_group / ops-prod_group ，本组只用于主账号级别的兜底场景

3.9 fin_group — 财务

项	内容
控制台备注	财务组(人) · 仅查账单与费用、无资源写权限、纯控制台无 AK（全文见 §3.0）
创建	2026-09-26 11:55
策略	AliyunBSSReadOnlyAccess（系统策略：费用中心只读） + newapi-audit-protect
成员	空 （尚未加入）
能做什么	看账单、账单明细、消费趋势、资源包/代金券余量、发票信息、按资源组/标签拆账；查 ActionTrail（audit-protect 里的 Describe 部分）
不能做什么	任何资源写操作 （VPC/ECS/RDS/OSS 全写不了）； 改不了账单本身 （付款、充值、改发票抬头、退订一律不行）；RAM 身份管理一律不行

项	内容
谁该进	财务/成本同学，1~2 人。 能进财务组的必须是企业自有身份，不要发 AK
注意	① 不需要绑 MFA —— 组内没有任何写权限，强制 MFA 只会带来困扰（想更严可以绑，无副作用）；② 若财务还要看 资源清单 （哪台机器花了多少钱），再额外挂系统策略 <code>ReadOnlyAccess</code> （全服务只读，含所有资源元数据）；③ 财务账号 只开控制台访问，不要创建 AK

为什么财务单独建组：`AliyunBSSReadOnlyAccess` 是**账号级钱包视角**的权限，能看整个账号的钱。放进 `ops_group` / `admin_group` 会让「运维/管理人员顺手看到全部账务」，与最小权限原则冲突；单独建组既满足财务只看账，又保证其他人看不到账单。

3.10 `dev_group` — 开发（人身份）

项	内容
控制台备注	开发组(人)·非生产读写、生产只读；AK 走 dev 程序组（全文见 §3.0）
创建	2026-09-26 12:15
策略	<code>newapi-ops-operator</code> + <code>newapi-enforce-mfa</code> + <code>newapi-audit-protect</code> + <code>newapi-prod-boundary</code> + <code>newapi-prod-oss-guard</code> （与 <code>ops_group</code> 逐条相同 ）
成员	<code>zhangzijun</code> 、 <code>xiangdong</code>
能做什么	非生产资源（ <code>rg-nonprod</code> ）全读写：OSS/RDS/Redis/ECS/安全组/路由；查看全部生产资源
不能做什么	任何生产资源写操作（两条边界策略 Deny）；删实例/库/集群/桶（ <code>ops-operator</code> 的 Deny）；RAM 身份管理
谁该进	开发同学的人身份 （控制台登录 + MFA）
注意	① 组里必须绑 MFA，否则 <code>newapi-enforce-mfa</code> 会 Deny 除自助绑定外的一切；② 开发同学的 AK 身份不在此处 —— 在 <code>dev-program_group</code> ，两个账号互不影响；③ 权限与 <code>ops_group</code> 完全等价 ，建这个组纯粹是为了语义分离，将来要收窄开发权限（如禁改网络层）只动这一个组

4. 七类角色的完整配置路径

按「谁 → 进哪个组 → 绑什么」逐类给出。命名统一约定：**人身份用真名**（如 `zhangzijun`），**程序身份加 `dev-` 前缀**（如 `dev-zhangzijun`）—— 看一眼名字就知道是控制台还是 AK。

4.1 管理人员 admin

新建用户 `admin-user` → 加入 `admin_group` → 绑 MFA → 完成

- 策略不用单独绑 —— 组里已有 3 条。
- 权限验证：`aliyun ram ListUsers` 能出结果；`aliyun vpc ModifyVpcAttribute`（生产）应报 `AccessDenied`。

4.2 财务 finance

`fin_group` 已创建，并已绑 `AliyunBSSReadOnlyAccess` + `newapi-audit-protect`。**加人即可，不用再建组。**

新建用户 `fin-<姓名>` → 加入 `fin_group` → 完成（不绑 MFA、不单独绑策略）

- 建用户时勾「**控制台访问**」，**不要**勾「OpenAPI 调用访问」（财务不需要 AK）。
- 密码重置/首次登录由 `admin_group` 成员操作。

财务角色**不需要** MFA 强制（组内没有任何写权限），想更严可以绑，无副作用。

4.3 开发 dev（人·控制台）

新建用户 `zhangzijun` → 加入 `dev_group` → 绑 MFA → 完成

- 能改 `rg-nonprod` 全部资源；生产资源只读；删实例/库/集群/桶被 Deny。
- **不要给这个人身份发 AK** —— 开发要用 AK 走 4.4 的程序身份。
- 权限与 `ops_group` **逐条相同**（见 §3.10），只是语义上归「开发」，便于将来单独调权限。

4.4 开发程序 dev-program（纯 AK）

另建用户 `dev-zhangzijun` → **【只勾 OpenAPI 调用访问】** → 加入 `dev-program_group` → 保存 AK

- **不要**给这个用户开控制台访问。
- AK 配到本地 SDK / CI secret，**严禁提交 git**。
- 权限：非生产 OSS 写 + 镜像推拉 + 全账号只读；生产写全挡。

4.5 开发 Leader

新建用户 dev-lead → 加入 dev_group (人身份: 可改非生产、可看生产)
→ 另建 dev-lead-program → 加入 dev-program_group (程序身份 AK)

- 人 / 程序两个身份分开建, 不要用同一个账号既登控制台又发 AK。
- 开发 Leader 与普通开发**权限相同**, 只是多承担评审职责; 若他还要管生产, 再叠加 ops-prod_group。

4.6 初级运维 ops

新建用户 ops-user → 加入 ops_group → 绑 MFA → 完成

- 日常运维同学进这里: 非生产读写 + 生产只读。
- 验证: 能改 rg-nonprod 资源; 改生产 VPC 应报 AccessDenied。
- 生产写被边界挡住是**有意设计**—— 别为「偶尔要改一次生产」解绑 newapi-prod-boundary, 那会让全组一起失去保护。

4.7 运维 Leader

新建用户 ops-lead → 加入 ops_group (保留) → 再加入 ops-prod_group → 绑 MFA → 完成

- 加入 ops-prod_group 让他拿到生产写权限 (**可写不可销毁**)。
- 若保留「非生产写」, 两个组都要在 (权限取并集)。
- ⚠ 本组**没挂** newapi-prod-oss-guard → 可删生产桶对象; 日常优先走 IaC, 手工变更须补回 Terraform。

4.8 七类角色权限对照 (能 / 不能)

角色	改生产资源	改非生产资源	管 RAM 身份	看账单	用 AK 调 API
管理人员	✗	✗	✓	只读	✗ (人身份无 AK)
财务	✗	✗	✗	✓	✗
开发 (人-控制台)	✗ (只读)	✓	✗	只读	✗ (人身份无 AK)
开发程序 (纯 AK)	✗ (只读)	✓ (OSS + 镜像)	✗	只读	✓
开发 Leader	✗ (只读)	✓	✗	只读	✓

角色	改生产资源	改非生产资源	管 RAM 身份	看账单	用 AK 调 API
初级运维	✗ (只读)	✓	✗	只读	✗ (人身份无 AK)
运维 Leader	✓ (不可销毁)	✓	✗	只读	✗

5. 控制台操作全流程

所有页面路径以「RAM 访问控制」控制台为准: <https://ram.console.aliyun.com>

5.1 前置：确认你有管理人员权限

1. 用 `admin_group` 中的用户（如 `admin`）登录 <https://ram.console.aliyun.com>
2. 左侧导航 → 身份管理 → 用户。若能看到用户列表 → 有权限
3. 若提示「您没有权限」，说明当前登录身份不在 `admin_group`，换该组内的账号登录

5.2 新增用户（3 步向导）

入口：左侧导航 → 身份管理 → 用户 → 右上角 创建用户



第 1 步 · 用户信息

字段	怎么填	注意
登录名称	姓名拼音，如 <code>zhangzijun</code> ；程序身份加前缀 <code>dev-</code> / <code>cicd-</code> / <code>iac-</code>	创建后不可修改
显示名称	中文姓名，如 <code>张子俊</code>	可随时改；不要和登录名混用
标签	<code>project=new-api</code>	便于筛选与分账，建议都打

填完点 **下一步**。



、`cicd-`、`iac-*`) 只勾此项，不要开控制台访问

第 2 步 · 访问方式 (关键步骤，勾错了要重建用户)

勾选项	给谁	后果
☒ 控制台访问	人：管理人员 / 财务 / 运维 / leader	生成初始密码；建议同时勾「要求下次登录时重置密码」+「需要 MFA」
☒ OpenAPI 调用访问	程序： <code>dev-*</code> / <code>cicd-*</code> / <code>iac-*</code> ；或需要 AK 的开发同学	生成 AccessKey ID/Secret

规则：

- 人 → 只勾「控制台访问」；**不要**给人发 AK (AK 绕过 MFA，见 §6.2)

- 程序 → 只勾「OpenAPI 调用访问」； **不要**给程序开控制台登录
- 开发同学若要既登控制台又写代码 → **建两个用户**： `zhangzijun`（控制台） + `dev-zhangzijun`（AK）

MFA 选项：人工身份建议勾上「需要 MFA 多因素认证」。但注意 —— 组里已挂 `newapi-enforce-mfa`，无论这里勾不勾， **未绑 MFA 前都干不了活**。



第 3 步 · 保存凭证

项	做法
控制台密码	点「复制」，通过安全渠道发给本人；勾了「要求重置」的话，首次登录会强制改
AccessKey Secret	只显示这一次 。点「下载 CSV 凭证」保存，或立即复制到密码管理器
AccessKey ID	可随时在用户详情里看到（ID 不是秘密，Secret 才是）

点 **完成**。

⚠ 若忘了保存 *Secret*：无法找回，只能**禁用旧 AK + 新建 AK**（见 §5.4）。

5.3 把用户加入用户组

入口 A（推荐，支持批量）：左侧导航 → 身份管理 → **用户组** → 目标组行尾 → **添加用户**



1. 在弹窗里搜索登录名称
2. 勾选要加入的用户（图示勾了 zhangzijun）
3. 点 **确定**

入口 B： 用户列表 → 点用户名进详情 → **用户组** 页签 → **添加用户组**

💡 **为什么一定要通过组？** 策略挂在组上，人进组即得权限。改权限时改一处（组），所有成员同步生效。

✅ **各用户组的策略已全部绑好**（逐组清单见 §3）。日常只需把用户加进对应组，**不需要再手工授权**。将来新建组才需要授权，走 §9 的脚本或控制台「新增授权」。

5.4 修改用户

入口： 用户列表 → 点登录名称进入用户详情

Alibaba Cloud

工作台

搜索

费用 备案 企业 支持 工单

yanxuewei

概览

设置

身份管理

用户

用户组

角色

权限管理

权限策略

授权

集成管理

SSO 管理

OAuth 应用 (公测)

多账号身份权限

访问分析

分析器

分析结果

AI 治理中心

RAM 访问控制 / 用户

用户

创建用户1 筛选登录名称、显示名称

	登录名称	显示名称	用户组	控制台访问	AccessKey	操作
☐	admin	admin	admin_group	已开启	0 个	移除用户：
☐	ops	ops	ops_group	已开启	0 个	移除用户：
☐	cicd-push	cicd-push	cicd-push_group	未开启	1 个	移除用户：
☐	iac-terraform	iac-terraform	iac-terraform_group	未开启	1 个	移除用户：
☐	zhangzijun	zhangzijun	dev_group	已开启	0 个	移除用户：
☐	xiangdong	xiangdong	dev_group	已开启	0 个	移除用户：
☐	dev-zhangzijun	dev-zhangzijun	dev-program_group	未开启	1 个	移除用户：
☐	dev-xiangdong	dev-xiangdong	dev-program_group	未开启	1 个	移除用户：
☐	yanxuewei	yanxuewei	super_group	已开启	0 个	移除用户：

要改什么	在哪改	操作
显示名称	用户详情 → 概览 → 显示名称右侧「修改」	直接改，即时生效
标签	用户详情 → 标签 → 编辑标签	可增删改
重置密码	用户详情 → 认证管理 → 控制台登录 → 修改登录密码	需当前操作者有 ram:UpdateLoginProfile
强制下次重置	同上 → 勾「要求下次登录时重置密码」	—
绑定/解绑 MFA	用户详情 → 认证管理 → MFA 设备 → 绑定	用手机 App 扫码，输入两次连续验证码
禁用 AK	用户详情 → 认证管理 → AccessKey → 目标 AK 行 → 禁用	禁用后可随时重新启用
新建 AK	同上 → 创建 AccessKey	Secret 只显示一次
删除 AK	同上 → 目标 AK 行 → 删除	不可恢复，依赖它的服务会立即中断
换用户组	用户详情 → 用户组 → 添加/移除	改组 = 改权限，立即生效

5.5 查询用户 / 用户组 / 权限归属

三种常用查法：

想知道	去哪查
某用户有哪些权限	用户详情 → 权限管理 页签（组策略 + 用户级策略）
某用户的 AccessKey 状态	用户详情 → 认证管理 → AccessKey
某条策略被谁用了	权限策略 列表 → 点策略名 → 引用记录 （Groups / Users / Roles 三个页签）
某用户属于哪些组	用户组 列表 → 逐个组查看成员；或用脚本 <code>./ram_user_mgmt.sh whoami <user></code>

Alibaba Cloud

工作台

搜索

费用 备案 企业 支持 工单

yanxuewei

概览

设置

身份管理

用户

用户组

角色

权限管理

权限策略

授权

集成管理

SSO 管理

OAuth 应用（公测）

多账号身份权限

访问分析

分析器

分析结果

AI 治理中心

RAM 访问控制 / 权限策略

创建权限策略

1

筛选策略名称、备注

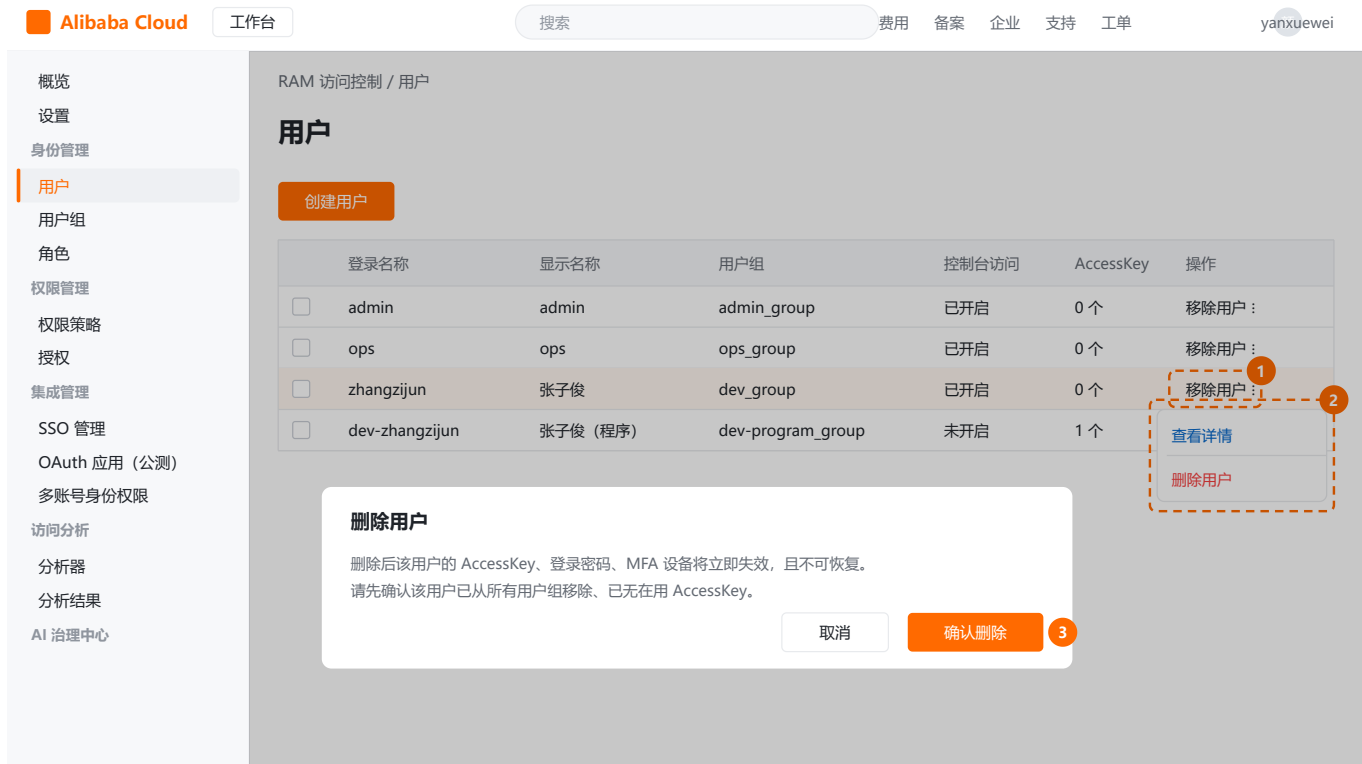
策略类型: 自定义策略

标签: 请选择

	策略名称	策略类型	备注	已关联授权	创建时间
☐	newapi-dev-program	自定义策略	—	1	2026年9月25日 22:29:57
☐	newapi-prod-oss-guard	自定义策略	—	3	2026年9月25日 22:24:37
☐	newapi-prod-boundary	自定义策略	—	3	2026年9月25日 22:24:36
☐	newapi-audit-protect	自定义策略	Deny write/delete of ActionTrail audit...	8	2026年9月25日 15:12:02
☐	newapi-oss-replication	自定义策略	CRR minimal: ReplicateGet on src, Repl...	1	2026年9月25日 13:39:58
☐	newapi-admin-identity	自定义策略	newapi admin: identity/audit managemen...	1	2026年9月25日 11:42:21
☐	newapi-enforce-mfa	自定义策略	true	5	2026年9月25日 11:41:00
☐	newapi-iac-terraform	自定义策略	newapi terraform: IaC minimum set incl...	1	2026年9月25日 11:39:24
☐	newapi-cicd-acr-push	自定义策略	newapi cicd: ACR pull/push limited to ...	1	2026年9月25日 11:39:04
☐	newapi-ops-operator	自定义策略	newapi ops: VPC/ECS/ACK/RDS/SLB/WAF/DN...	3	2026年9月25日 11:38:47

上图「已关联授权」列就是引用计数。点进去可以看具体挂在哪。

5.6 删除用户（必须按顺序）



顺序不能错：

1. **先从所有用户组移除** —— 用户组列表 → 目标组 → 成员页签 → 勾选 → **移除用户**
| 存在成员时**无法删除用户组**，所以这一步也是删组的前置。
2. **回用户列表** → 目标用户行尾 → **:** → **删除用户**
3. 二次确认弹窗点 **确认删除**

删除前自查清单：

检查项	命令 / 位置
是否属于任何用户组	用户详情 → 用户组页签应为空
是否还有 Active 的 AK	用户详情 → 认证管理 → AccessKey；有则先禁用并确认无服务在用
是否绑了 MFA、是否有登录密码	有则一并失效，确认本人已知悉
是否有 CI/脚本在用这个身份	搜代码库与 CI secret

⚠️ **删除不可恢复。** 删除后该用户的 AK 立即失效，依赖它的服务会中断。

💡 **更安全的做法：**先禁用 AK、观察一周，确认无调用后再删除用户。

5.7 修改用户组备注（不要手动改，直接交给相关同学用脚本批量改）

⚠️ 手工逐个改容易漏、容易写错 (10 个组要改 10 次)。推荐用 `ram_group_annotate.sh` : 备注文本集中在脚本 `comments_for()` 里作为**唯一真源**, 一次 `apply` 全量对齐, 改错了能 `rollback`。

```
export ALIYUN_BIN="$HOME/.workbuddy/binaries/aliyun-cli/aliyun"
bash ram_group_annotate.sh check      # 只读: 对比当前 vs 目标
bash ram_group_annotate.sh apply     # 备份 + 写入 (幂等)
bash ram_group_annotate.sh verify    # 校验 10/10 一致 + 长度合规
```

备注写法约定 (本账号统一格式, 实际文本见 §3.0) :

<角色/用途> | 策略:<策略清单> | 注意:<边界与坑>

- 长度**上限 128 字符** (中文按 1 字符计), 超了接口直接报错。
- **不要写敏感信息** —— 备注对账号内所有能看用户组的人明文可见, AK / 密码 / token / 内网 IP 一律不进备注。
- 写「**不能干什么**」比写「能干什么」更有价值: 看备注的人通常是想确认边界在哪。

6. 注意事项 (按重要性排序)

6.1 Deny 恒胜 Allow —— 权限给不出去的常见原因

现象: 给用户加了 Allow 策略, 他还是报 `AccessDenied`。

原因: 他所属的**另一个组**里有 Deny 语句。

典型: `ops_group` 挂着 `newapi-prod-boundary` (Deny 生产写)。往 `ops_group` 加任何 Allow 都救不回生产写权限。**正确做法是把他加到 `ops-prod_group`, 或从 `ops_group` 移除。**

6.2 不要给人发 AK

`newapi-enforce-mfa` **只约束控制台会话**。AK 调用没有 MFA 上下文, 条件不成立 → 该策略对 AK 完全不生效。

⇒ 一旦人的 AK 泄露, 攻击者绕过全部 MFA 保护。

正确形态: 人要写代码 → 单独建 `dev-<姓名>` 程序身份, 只给最小权限。

6.3 策略只挂组, 不挂用户

铁律。用户级 + 组级双绑会形成两层漂移:

- 改了组策略但用户级旧策略还在 → 改了不生效

- 删了用户级但组里没有 → 权限直接消失

临时提权请用「临时组 + 到期移除」，不要 `AttachPolicyToUser`。

6.4 纯程序身份不要建控制台登录

`dev-*` / `cicd-*` / `iac-*` 如果同时有控制台密码，等于多了一条绕过 MFA 的路径（密码泄露 + 无 MFA 强制）。

检查是否有登录配置：

```
aliyun ram GetLoginProfile --UserName dev-zhangzijun --region ap-southeast-1
# 期望返回 EntityNotExist.User.LoginProfile
```

6.5 生产桶对象可被 `ops-prod_group` 成员删除

`newapi-ops-operator` 的 Deny 列表里没有 `oss:DeleteObject`，而 `ops-prod_group` 也没挂 `oss-guard`。

⇒ 该组成员能删 `oss-newapi-mnl/rds-backup/*`（RDS 备份）、`oss-newapi-mnl/actiontrail/*`（审计日志被 `audit-protect` 另外保护）。

若要堵住：给 `ops-prod_group` 也挂 `newapi-prod-oss-guard`。但那样生产桶就写不了了 —— 按需要取舍。

6.6 建资源必须指定资源组，顺序不能反

类型	做法
VPC 类	<code>CreateVpc --ResourceGroupId <rg></code> 先放组，再建 vSwitch（vSwitch 继承 VPC 的组，且不可事后单独转移）
OSS 桶	建完用 <code>ossutil api put-bucket-resource-group</code> 迁移
ACR	建完用 <code>aliyun cr ChangeResourceGroup --ResourceRegionId <region></code>

铁律：资源组必须在创建时定。落错组 + 已有依赖 = 只能返工重建。

6.7 直接改策略要发新版本

`CreatePolicyVersion --SetAsDefault true` 才会让新内容生效。只调 `CreatePolicyVersion` 不发版，权限不变 —— 这是最容易踩的坑之一。

```
aliyun ram CreatePolicyVersion --PolicyName <p> \
  --PolicyDocument "$(cat new.json)" --SetAsDefault true --region ap-southeast-1
```

6.8 用户组备注：128 字符上限，且不写敏感信息

- RAM 的 `Comments`（用户 / 用户组）**上限 128 字符**，中文按 1 字符计。超长会报 `InvalidParameter` 类错误。
- 当前 `ops_group` 备注 **127 字符，几乎顶到上限**——下次想加内容必须先删旧内容。
- 备注是**明文**展示给所有能查看用户组的人，**不要**把 AK、密码、token、内网 IP 写进去。只写「用途 / 策略 / 边界」。
- 备注**不影响权限**：改备注不会改权限，权限永远由挂在组上的策略决定。别把备注当权限开关。

⚠ **脚本 `apply` 会覆盖控制台的手工改动。备注的唯一真源是 `ram_group_annotate.sh` 的 `comments_for()`。**

在控制台改了备注 → 必须同步回脚本，否则下次 `apply` 会把它改回去。

万一被覆盖了：备份在 `.workbuddy/ram_group_comments/backup_<时间戳>.tsv`，用 `rollback` 或直接比对备份取回。

稳妥做法：改备注一律走脚本；只在紧急情况下动控制台，动完立刻同步脚本。

7. 常见出错与解决方法

#	错误信息 / 现象	原因	解决方法
1	<code>EntityAlreadyExists.User</code>	登录名称已被占用	换名，或先搜同名用就是目标
2	<code>EntityNotExist.User.LoginProfile</code>	该用户没有控制台登录配置	正常（程序身份就该要开，用户详情 → 启用控制台登录
3	<code>NoPermission</code> / 您没有权限执行该操作	当前登录身份不在 <code>admin_group</code> / <code>super_group</code>	换管理人员账号操作
4	绑了策略但用户仍 <code>AccessDenied</code>	Deny 优先，别的组里挡着	见 §6.1 排查；确认月
5	创建用户后登录控制台，除「绑定 MFA」外全部报错	<code>newapi-enforce-mfa</code> 生效，但本人还没绑 MFA	先进「认证管理 → MFA 绑定，绑完立即恢复
6	<code>Throttling.User</code> / 请求被限流	RAM API 调用频率超限	等待 1~2 分钟重试；加 <code>sleep 1</code>
7	删除用户报 <code>EntityInUse</code>	还属于某个用户组，或还有 AK	先 <code>RemoveUserFromGroup</code> 删 AK
8	删除用户组报 <code>EntityInUse.Group</code>	组里还有成员或还挂着策略	先移除全部成员，再删策略

#	错误信息 / 现象	原因	解决方法
9	忘了 AccessKey Secret	Secret 只在创建时显示一次，无法找回	禁用旧 AK → 新建 A 用方配置 → 删除旧
10	aliyun: command not found	PATH 未包含 CLI	见 §8.1; 或用绝对路 ~/.workbuddy/binar cli/aliyun
11	load configure failed	未配置凭证 / 配置损坏	aliyun configure - default --mode AK
12	Forbidden.RAM 或 Forbidden	有权限但资源不存在（存在性校验先于鉴权）	确认资源 ID 与 regic 幂等写操作验证权限
13	InvalidResourceGroupId	资源组 ID 写错，或该资源组不在此 region	用 aliyun resource ListResourceGroups ap-southeast-1 核
14	新建策略后权限没变	没发新版本 / 没设默认版本	CreatePolicyVersio SetAsDefault true
15	加了 Allow 却还是写不了生产桶	newapi-prod-oss-guard 或 newapi-prod- boundary 挡着	确认目标身份是否属 条策略的组
16	用户组页面找不到某条策略	筛选默认只显示「自定义策略」	切到「系统策略」页
17	ActionTrail 里看不到操作记录	跟踪未开启，或查询用了错误的 region	见 ActionTrail审计 报告.md；查询用 LookupEvents --reg southeast-6
18	保存用户组备注报 InvalidParameter / 备注被截断	备注超过 128 字符上限	精简到 128 字符内； ram_group_annotate 它会算出每组字数
19	财务同事登录控制台看不到账单	不在 fin_group，或组里缺 AliyunBSSReadOnlyAccess	aliyun ram ListPoliciesForGro GroupName fin_grou ap-southeast-1 核 户已 AddUserToGrou

9. 配套脚本 ram_group_annotate.sh （用户组备注 + 特殊组策略）

ram_user_mgmt.sh 管用户；这个脚本管用户组的备注 + 特殊组的策略绑定（fin_group / dev_group / power_user_group），两个脚本互补。

命令	作用	是否写云端
check	对比 10 个组「当前备注 vs 目标备注」，列出差异	只读
apply	① 备份当前备注到 <code>.workbuddy/ram_group_comments/</code> ② 建/补特殊组策略： <code>fin_group</code> (2 条)、 <code>dev_group</code> (5 条)、 <code>power_user_group</code> (补 <code>enforce-mfa</code> + <code>audit-protect</code>) ③ 写入 10 组中文备注	✅ 幂等
verify	校验 3 个特殊组的策略 + 10 组备注是否 10/10 一致，并打印每组字符数	只读
rollback	从最近一次备份恢复备注	✅

```
export ALIYUN_BIN="$HOME/.workbuddy/binaries/aliyun-cli/aliyun"
bash ram_group_annotate.sh check      # 先看差异
bash ram_group_annotate.sh apply      # 备份 + 写入
bash ram_group_annotate.sh verify     # 校验
```

改备注的正确姿势：编辑脚本里的 `comments_for()` 函数（唯一真源）→ 跑 `verify` 看字数是否超 128 → `apply` 生效。

10. 附录

10.1 当前账号资源快照（2026-09-26）

用户 9 个： `admin`、`ops`、`cicd-push`、`iac-terraform`、`zhangzijun`、`xiangdong`、`dev-zhangzijun`、`dev-xiangdong`、`yanxuewei`

用户组 10 个： `admin_group`、`ops_group`、`ops-prod_group`、`dev_group`、`dev-program_group`、`iac-terraform_group`、`cicd-push_group`、`fin_group`、`power_user_group`、`super_group`

用户组	成员	备注字符数
<code>admin_group</code>	<code>admin</code>	103
<code>fin_group</code>	空	104
<code>ops_group</code>	<code>ops</code>	127
<code>ops-prod_group</code>	空（留备）	106
<code>dev_group</code>	<code>zhangzijun</code> 、 <code>xiangdong</code>	122
<code>dev-program_group</code>	<code>dev-zhangzijun</code> 、 <code>dev-xiangdong</code>	119

用户组	成员	备注字符数
iac-terraform_group	iac-terraform	105
cicd-push_group	cicd-push	91
power_user_group	0 人	97
super_group	yanxuewei	49

自定义策略 10 条：见 §2

服务关联角色：aliyunosssystemdefaultrole (CRR)、AliyunServiceRoleForActionTrail (审计投递)

10.2 资源组 ID 速查

资源组	ID	内容
默认	rg-acfnssmgwnsb5oa	仅系统遗留，禁止放 new-api 资源
rg-ph-mn1	rg-aek4nyivmmsb6iy	马尼拉生产
rg-sg	rg-aek4zvb3ldoiyua	新加坡生产（备站）
rg-nonprod	rg-aek4hk3prqgqjcy	staging + perf + 压测
rg-shared	rg-aek3yypouljf4ry	跨站共享：ACR、ActionTrail、CMS

⚠️ newapi-prod-boundary 里的条件键写的是 rg-ph-mn1 / rg-sg 的 ID。若这两个资源组被重建 (ID 变化)，必须同步更新策略并发布新版本。